State Capitol P.O. Box
2062 Albany, NY 12220-
0062
www.its.ny.gov

New York State Information Technology Standard	**No: NYS-S20-001**
IT Standard **Digital Identity**	**Updated:** 09/08/2026
	Issued By: NYS Office of Information Technology Services **Owner:** Chief Information Security Office

1.0 Purpose and Benefits

This standard establishes a framework for issuing and managing trusted identity credentials to allow residents, businesses, and government employees to conduct business through New York State (NYS) information systems. A trusted identity credential provides the State Entity (SE) with sufficient confidence that it accurately represents the specific individual engaged in the electronic transaction.

The purpose of this standard is to establish the rules and processes for maintaining and protecting NYS identity data, including the tokens and credentials issued and bound to each identity.

The standard establishes a trustworthy process, based on the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63 Digital Identity Guidelines, for

- Identity proofing individuals.
- Managing authentication credentials that are tied to an individual's digital identity.
- Connecting that digital identity to the individual.

2.0 Authority

Section 103(10) of the State Technology Law provides ITS with the authority to establish statewide technology policies, including technology and security standards. Section 2 of Executive *Order No. 117*[1], established January 2002, provides the State Chief Information Officer with the authority to oversee, direct and coordinate the establishment of information technology policies, protocols, and standards for State government, including hardware, software, security, and business re-engineering. Details regarding this authority can be found in NYS ITS Policy, *NYS-P08-002 Authority to Establish Enterprise Information Technology (IT) Policies, Standards and Guidelines.*

3.0 Scope

This standard applies to all "State Entities" (SE), defined as "State Government" entities in Executive Order 117 or "State Agencies" as defined in Section 101 of the State Technology Law. This includes employees of the SE and ITS and all third parties (such as local governments, consultants, vendors, and contractors) that use or access any IT resource for which the SE or ITS has administrative responsibility, including systems managed or hosted by third parties on behalf of the SE or ITS. While an SE may adopt a different standard, it must include the requirements set forth in this one. Where a conflict exists between this standard and an SE's standard, the more restrictive standard will take precedence.

This standard is applicable to the authentication of all individuals or systems using or accessing NYS applications and systems for the purposes of conducting government business electronically. This includes all test, quality control, production, and other ad hoc systems.

4.0 Information Statement

NYS has generally adopted the NIST SP 800-63-4: Digital Identity Guidelines, as the basis for reliable, secure, and privacy-protective digital identity standards where applicable and practical.

To ensure a digital identity of a user in the context of an *online service*, SEs are required to select an assurance level for each of the following functions:

- **Identity Assurance Level (IAL)** refers to identity proofing functions.
- **Authentication Assurance Level (AAL)** refers to authentication functions.
- **Federation Assurance Level (FAL)** refers to federation functions when the *Relying party (RP)* is connected either to a *Credential Service Provider (CSP)* or

[1] All references to Executive Order 117 refer to that which was originally issued by Governor George E. Pataki on January 28, 2002 and continued by Executive Order 5 issued by Governor Eliot Spitzer on January 1, 2007, Executive Order 9 issued by Governor David A. Patterson on June 18, 2008, Executive Order 2 issued by Governor Andrew M. Cuomo on January 1, 2011 and Executive Order 6 issued by Governor Kathy Hochul on October 8, 2021.

an *Identity Provider (IdP)* through a federated protocol. Definitions for RP, CSP, IdP, and other terms can be found in Section 6.

NIST SP 800-63-4: Digital Identity Guidelines defines baseline assurance levels as control sets, offering SEs risk management starting points and interoperability structure between different entities. However, since no assurance level can cover all risks and considerations, these guidelines promote a risk-based, not compliance-based, approach. SEs are encouraged to tailor their control implementations based on the processes outlined in this standard.

4.1 Digital Identity Risk Management

The Digital Identity Risk Management (DIRM) process involves assessing digital identity risks and using those assessments, along with additional considerations, to select controls for identity proofing, authentication, and federation. Controls are chosen by determining the required assurance levels (i.e., IAL, AAL, and FAL) to mitigate specific digital identity errors for a given service based on risk and mission needs as well as any assurances stipulated by regulatory requirements.

Aligned with NIST's 7-step Risk Management Framework (RMF), NYS-S14-001 Information Security Risk Management, and NIST SP 800-63-4: Digital Identity Guidelines, DIRM establishes a five-step process for ensuring a robust risk intelligent infrastructure that protects the digital identity of users (see Figure 1). This is grounded on the following five pillars:

1. **Context** - *Define the online service*: The DIRM process begins by documenting the online service's functional scope, intended users, transaction types, and data processed. If the online service is a part of a larger business process, its role and data usage are also documented. SEs must identify all entities impacted by the service and its broader process.

2. **Identify Risks / Vulnerabilities** - *Conduct initial impact assessment*: In this step, SEs focus on risks stemming from operating the online service that an identity system can mitigate. This includes identifying potential adverse impacts from failures in identity proofing, authentication, or federation that are specific to an online service. SEs must identify applicable *impact categories* (e.g., degradation of mission delivery, damage to trust/reputation etc.), and *potential harms*, then determine *impact levels* (Low, Moderate, or High). Each user group is assessed separately, considering their distinct transactions and privileges within the online service.

3. **Assessment / Impact Analysis** - *Select initial assurance levels*: In this step, the impact categories and impact levels are evaluated to determine the initial assurance levels to protect the online service from unauthorized access and fraud. Using the assurance levels, the organization identifies the baseline

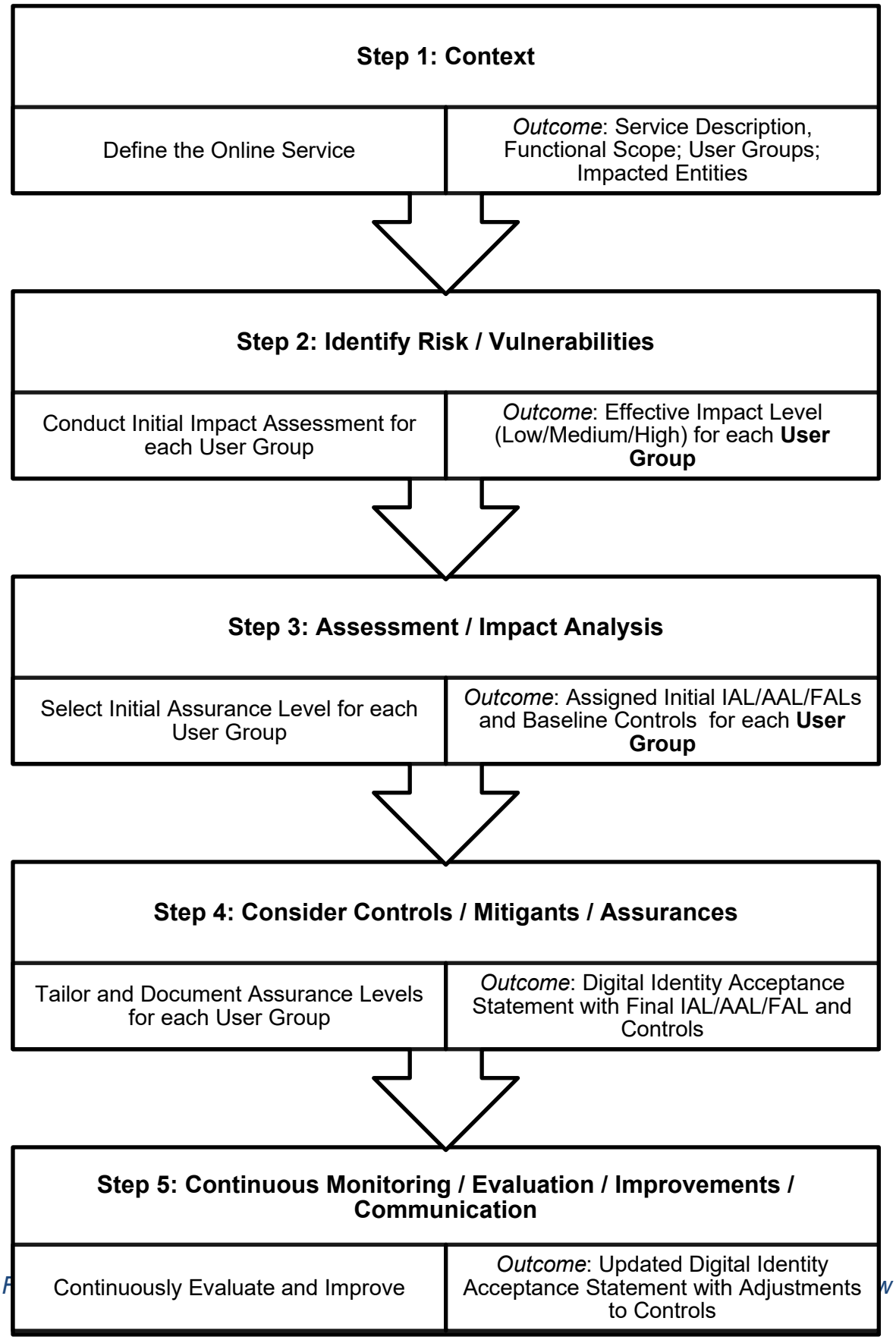
controls for the xALs[2] for each user group. The requirements for xALs are covered from Section 4.2 onwards.

4. **Consider Controls / Assurances** - *Tailor and document assurance level determinations*: This step provides a process to modify an initially assessed assurance level and implement compensating or supplemental controls based on ongoing detailed risk assessments. These risks stem from the identity system itself, specific environmental threats, and impacts of privacy and customer experience. The final implemented xALs do not all need to be at the same level. There may be variances based on the functions of the online service, the impact assessment, and the tailoring process (see 'Digital Identity Acceptance Statement' in NIST 800-63-4).

5. **Continuously Monitor, Evaluate, Communicate** - *Continuously evaluate and improve*: This step gathers and evaluates performance information for the identity management approach to keep pace with the evolving threat and technology environment and identify programmatic gaps. Key activities include leveraging end-user feedback, performance metrics, monitoring the threat landscape, and integrating insights from customer experience, privacy assessments, and fraud trends. It also emphasizes designing redress mechanisms for fair and transparent user resolution. Like the overall DIRM process, this step is iterative, often requiring revisiting previous steps due to environmental, functional, or threat changes.

The significance of DIRM for SEs is further detailed in Appendix A.

[2] When described generically or bundled, this document will refer to IAL, AAL, and FAL as xAL. Each xAL has three assurance levels.


Step 1: Context
Define the Online Service
Outcome: Service Description, Functional Scope; User Groups; Impacted Entities
Step 2: Identify Risk / Vulnerabilities
Conduct Initial Impact Assessment for each User Group
Outcome: Effective Impact Level (Low/Medium/High) for each **User Group**
Step 3: Assessment / Impact Analysis
Select Initial Assurance Level for each User Group
Outcome: Assigned Initial IAL/AAL/FALs and Baseline Controls for each **User Group**
Step 4: Consider Controls / Mitigants / Assurances
Tailor and Document Assurance Levels for each User Group
Outcome: Digital Identity Acceptance Statement with Final IAL/AAL/FAL and Controls
Step 5: Continuous Monitoring / Evaluation / Improvements / Communication
Continuously Evaluate and Improve
Outcome: Updated Digital Identity Acceptance Statement with Adjustments to Controls

4.2 Identity Proofing and Enrollment

Identity proofing aims to confirm an applicant's claimed identity to a defined level of confidence, corresponding to an IAL. Upon the successful completion of identity proofing, the applicant is enrolled into a *subscriber* account. This section covers the requirements for identity proofing individuals at various IALs. This process necessitates defined roles for consistent implementation and CSPs are required to identify relevant roles and offer training. For technical specifications on roles and their hiring requirements, please refer to NIST SP 800-63A-4 Digital Identity Guidelines – Identity Proofing and Enrollment.

To initiate identity proofing and enrollment, a CSP must first define the core identity attributes. These attributes commonly include first name, middle name or initial, last name, date of birth, and physical or digital address. Both the CSP and the RP may augment these with additional attributes as required. After the CSP conducts a privacy risk assessment, they may request supplementary attributes that are not strictly necessary for identity proofing but beneficial for other RP business functions.

The typical phases of the identity proofing and enrollment process are as follows (an illustrative diagram is provided in Appendix B):

a. **Identity Resolution**: Confirm that the claimed identity matches a single, unique individual among the CSP's or online service's subject.

b. **Identity Validation**:

    i. **Evidence Validation**: Verify that the provided identity documents are real, authentic, and accurate.

    ii. **Attribute Validation**: Ensure the core information needed for identity proofing and service delivery is correct.

c. **Identity Verification**: Confirm the applicant is the actual owner of the presented evidence and attributes.

d. **Identity Enrollment**: Add the verified applicant to the CSP's identity service as a subscriber.

e. **Fraud Mitigation**: Identify, handle, and prevent unauthorized access to benefits, services, data, or assets using a fake identity.

Assurance in a *subscriber's* identity established using the processes above are associated with the IAL – see Table 1. Each successive IAL builds on the requirements of lower IALs to achieve increased assurance.

CSPs must evaluate identity proofing risks, implement mitigating fraud controls, and ensure all offered options provide comparable aggregate assurance. To ensure accessibility for all applicants, it is recommended that SEs implement flexible identity

proofing services that include multiple options for evidence, validation sources, verification methods, and exception handling. This approach promotes inclusivity by accommodating different applicants' means, capabilities, and technologies. The sections below provide guidance to the SEs, CSPs, and Information Owners in identifying and implementing the appropriate technical requirements for the various phases in identity enrollment and proofing.

Table 1: IAL Summary

Assurance Level	Description
No identity proofing	No requirement to link the applicant to a specific, real-life person. Identity proofing is not required in two scenarios: when an online service doesn't need personal information for digital transactions, or when the potential risk from accepting self-asserted attributes is low based on DIRM.
IAL1	Low Assurance. Confirms real-world existence and association with claimed identity. Validates core attributes against authoritative sources. Can be remote/on-site.
IAL2	Stronger assurance. Requires more evidence such as a drivers license or passport and uses rigorous validation and verification of presented evidence. Can be remote/on-site.
IAL3	Highest assurance. Requires on-site interaction with a trained CSP agent and at least one biometric characteristic.

4.2.1 Identity Collection and Resolution

The CSP must collect a minimum amount of evidence and attribute information that is needed for identity proofing and to distinguish a unique identity. See Appendix C for different levels of strength for identity evidence (FAIR, STRONG, SUPERIOR), to establish a valid identity. Furthermore, the identity proofing method considers *identity proofing type*, i.e., the location of proofing (*remote* or *on-site*) and whether a CSP agent is present or absent during the process (*attended* or *unattended* respectively). See Appendix D: Identity Proofing Types for further information. Table 2 specifies the minimum evidence and attribute information that the CSP is required to collect for identity proofing and to establish a unique identity.

Table 2: Identity Collection and Resolution Requirements

Assurance Level	Identity Proofing Type	Evidence Collection	Attribute Collection
No Identity Proofing	No Identity proofing type requirements	Not Required	Attributes may be collected.
IAL1	Identity proofing may be delivered through **any proofing type**, including remote or on-	CSPs shall collect ONE piece of: ○ 1 **FAIR** evidence that can be	The CSP must **collect all core attributes**, including

Assurance Level	Identity Proofing Type	Evidence Collection	Attribute Collection
	site, and attended or unattended. Refer sections 4.1.7, 4.1.8, 4.1.9, and 4.1.10 of NIST SP 800-63A-4 for specific requirements IAL1 proofing type requirements.	digitally validated or that includes a facial portrait or other biometric, or ○ **STRONG** evidence, or ○ **SUPERIOR** evidence.	**at least one government identifier**, prioritizing validated evidence. If validated evidence is insufficient for all core attributes, the **CSP may collect self-asserted attributes** from the applicant.
IAL2	Identity proofing may be delivered **remotely or on-site, and attended or unattended**. CSPs may combine these proofing types to create hybrid processes. Refer sections 4.2.7, 4.2.8, 4.2.9, and 4.2.10 of NIST SP 800-63A-4 for specific IAL2 proofing type requirements.	CSPs shall collect: ○ 1 FAIR + 1 STRONG, or ○ 2 STRONG, or ○ 1 SUPERIOR	Attribute collection is **the same as IAL1**.
IAL3	Identity proofing **must be delivered on-site and attended**. The proofing agent can be co-located with the applicant or attend via a CSP-controlled kiosk or device. Refer sections 4.3.7 and 4.3.8 of NIST SP 800-63A-4 for specific IAL3 proofing type requirements.	Evidence collection requirements are the same as IAL2.	Attribute collection is **the same as IAL2**. Additionally, during identity proofing, the **CSP must also collect and retain *a biometric sample*** to support account recovery, non-repudiation, and participant presence verification. CSPs may periodically re-enroll biometrics

Assurance Level	Identity Proofing Type	Evidence Collection	Attribute Collection
			based on modality and account persistence.

4.2.2 Identity Evidence and Attribute Validation

Identity *evidence validation* confirms its authenticity, accuracy, and validity (unexpired or within CSP timeframe) by checking its format and physical or digital features. In *attribute validation,* a CSP confirms the accuracy of core attributes and government identifiers, whether from evidence or self-asserted, with an authoritative or credible source[3]. Table 3 lists the IAL requirements for validating evidence and an applicant's core attributes.

Table 3: Identity Evidence and Attribute Validation Requirements

Assurance Level	Evidence Validation	Attribute Validation
No Identity Proofing	Not Required	Attribute validation is optional for business purposes, not a prerequisite for security.
IAL1	Each evidence requires validation through one of these methods: • **Digital Evidence**: Confirm authenticity by interrogating digital security features (e.g., signatures on assertions or data). • **Physical Evidence**: ○ Confirm authenticity using automated scanning that can detect physical features. ○ Confirm the integrity of physical security features by a proofing agent through visual inspection	CSPs should ensure **attribute consistency** from various sources (evidence, self-asserted, authoritative/credible) and validate **reference numbers** on presented identity evidence, if available.

[3] An **authoritative source** is the original issuer of identity evidence or attributes (e.g., DMVs, SSA), or has direct access to their data (e.g., AAMVA DLDV). A **credible source**, subject to regulatory oversight (like FCRA), accesses attribute information traceable to authoritative sources or correlates data from multiple sources for accuracy, consistency, and currency NIST SP 800-63A-4 .

Assurance Level	Evidence Validation	Attribute Validation
	(real-time or asynchronous) or on-site physical and tactile inspection.	
IAL2	Same as IAL1, plus for **SUPERIOR Evidence**, Digital signature verification.	Same as IAL1.
IAL3	Same as IAL2.	Same as IAL2.

4.2.3 Identity Verification

The CSP verifies that the applicant is the rightful owner of the presented evidence, establishing a link between their claimed identity and their real-life self to a specified level of confidence. Table 4 outlines the minimum prerequisites for the verification of an applicant's identity, with different requirements for various assurance levels.

Table 4: Identity Verification Requirements

Assurance Level	Verification Requirements
No Identity Proofing	No formal identity verification is performed.
IAL1	The CSP must verify the *applicant's* ownership of **one** piece of evidence (FAIR/STRONG/SUPERIOR) by using **any** of the following methods: ● **Mailed confirmation code verification** - Confirming applicant's access to a validated address via a confirmation code ● **Microtransaction verification** - Confirming applicant's access to a validated financial or similar account via a microtransaction ● **AAL2/FAL2+ authentication** - Ensuring applicants' ability to successfully complete an AAL2/FAL2+ authentication/federation protocol for an associated account ● **Manual facial image verification** – Performing manual comparison of applicant's facial image with a facial portrait on evidence or records in one of the following three ways ○ *On-site attended*: In-person verification with a proofing agent.

Assurance Level	Verification Requirements
	○ *Remote attended*: Live video verification with a proofing agent. ○ *Asynchronous process*: A proofing agent reviews and compares the images later ● **Automated facial image verification –** Performing an automated comparison of applicant's facial image to a facial portrait on evidence or records. **PAD Defenses** – CSPs must implement Presentation Attack Detection (PAD)[4] and passive/active document presence checks for asynchronous/offline manual identity verification.
IAL2	CSPs should deploy **more than one of the three existing verification pathways** – Non-Biometric, Biometric, and Digital Evidence – for the verification of all presented evidence and may combine them to achieve desired outcomes. ***Non-Biometric Pathway*** - Verification methods that use manual comparison of biometric samples provided by the applicant. ● Proofing Types: For remote (attended/unattended) and on-site unattended, the CSP verifies ownership of all evidence. For on-site attended, only the strongest evidence needs verification. ● FAIR evidence: ○ Mailed confirmation code verification **or** ○ Facial image verification. ● STRONG and SUPERIOR evidence: ○ Mailed confirmation code verification **or** ○ Facial image verification with PAD Defenses ***Digital Evidence Pathway*** - Verification methods that use digital forms of evidence such as digital credentials/digital identity documents or digital accounts. ● Proofing Types: Same as non-biometric pathway ● FAIR evidence: ○ Microtransaction verification **or** ○ AAL2/FAL2+ Authentication **or**

[4] Presentation Attacks - Presentation to the biometric data capture subsystem with the goal of interfering with the operation of the biometric system. Also referred to as 'spoofing' in common parlance.

Assurance Level	Verification Requirements
	○ Confirming applicant's access to a validated digital address associated with the digital evidence via a confirmation code ● STRONG evidence: ○ AAL2/FAL2+ Authentication ● SUPERIOR evidence: ○ Confirming access by verifying the applicant's possession of the evidence through a local activation factor and a cryptographically verifiable attribute bundle. ***Biometric Pathway*** – Verification methods that perform automated comparison of biometric samples provided by the applicant. ● Proofing Types: Same as non-biometric pathway ● FAIR, STRONG and SUPERIOR evidence: ○ Automated facial image verification **or** ○ Automated biometric comparison (non-facial) of evidence to a live applicant sample.
IAL3	CSP shall verify ownership of all presented evidence (STRONG or SUPERIOR) through one of the following methods: ● Verifying applicants' authenticated access to a physical device or application (like a mobile driver's license, or mDL) **and** comparing a digitally protected and transmitted facial portrait to the applicant. **or** ● Automated facial image verification ● Manual facial image verification (on-site/remote attended) ● Automatically compare a stored biometric (fingerprint, face scan, etc.) from the ID or authoritative records with a sample the applicant provides.

4.2.4 Identity Enrollment - Subscriber Account

After successful verification, the CSP (or IdP in case of federation) creates an account for the new *subscriber* in its identity system. This account, managed by the CSP, serves

to **identify the subscriber uniquely** and store all ***associated authenticators*** until the account is closed. To minimize the need for account recovery, CSPs should encourage subscribers to bind at least two separate means of authentication (see Authentication Binding in NYS-S14-006 Authenticators for IAL specific requirements).

The CSP may enroll and establish subscriber accounts for applicants who have not been identity proofed. These accounts will be referred to as *pseudonymous accounts*, and their status will be recorded in the subscriber account.

Each subscriber account must minimally contain: the unique account identifier, any subject identifiers (including RP specific ones), a record of completed identity proofing steps (detailing evidence, method, validation, verification pathways, exceptions, applicant references, and achieved IAL), records of applicant consent agreements (including biometrics), all bound authenticators, and attributes validated for RP access.

The CSP must enable subscribers to authenticate and access their account information. For subscriber accounts containing Personally Identifiable Information (PII), access requires multi-factor authentication (MFA). This includes AAL2 or AAL3 authentication processes, utilizing authenticators that are registered to the subscriber account. (see 4.4 and NYS-S14-006 Authenticators for further reference).

The CSP must validate changes to subscriber account data (excluding physical addresses, unless deemed a core attribute), notify subscribers of all updates, and offer a mechanism for reporting unauthorized access or compromises.

4.2.4.1 Subscriber Account Suspension or Termination

The CSP must promptly suspend or terminate a subscriber account under specific conditions, including but not limited to, subscriber request, account compromise, policy violation, inactivity, death, legal order, or cessation of services. Upon suspension or termination, the CSP must notify the subscriber with details on the reason, reactivation options, and redress, and subsequently delete all personal information according to retention policies.

4.3 Fraud Mitigation

Fraud mitigation measures are required for all digital account creations and transactions, even when no identity proofing is performed. SEs must implement risk-based controls such as device fingerprinting, behavioral analysis, velocity limits, and third-party risk scoring to prevent synthetic identity fraud and unauthorized access. For example, requiring SMS verification of a mobile number which has been verified as associated with the subject via a service can drastically reduce fraudulent sign-ups while maintaining low subject friction.

In addition, there are four general categories of threats to the identity proofing process that should be considered and addressed accordingly using DIRM (Section 4.1):

- *Impersonation*: An attacker attempts to pose as another legitimate individual.
- *False or fraudulent representation*: An attacker attempts to create a false identity

or false claims about an identity.

- *Social engineering attacks*: An attacker attempts deceptive or coercive tactics to convince a victim into actions that grant attackers access to subscriber accounts.

- *Infrastructure attacks*: An attacker attempts to compromise the confidentiality, integrity, or availability of the infrastructure, data, software, or people supporting the CSP's identity proofing process.

Appendix E: Fraud Mitigation Strategies provides examples of these threat categories and their mitigation options. For additional security mitigations, refer to NYS-S14-001 Information Security Risk Management and NIST SP 800-53 Rev. 5 Recommended Security and Privacy Controls for Federal Information Systems and Organizations.

For guidance on advanced threats such as AI attacks (deepfake, etc.) and forged media, see Section 3.14 of NIST SP 800-63A-4.

4.4 Authentication and Authentication Management

Authentication is the process where a *claimant* proves they possess and control *authenticators* linked to a *subscriber* account, thereby demonstrating they are the legitimate subscriber. Figure 2 depicts a common interaction sequence in a digital identity model for a subject: an *applicant* enrolls with a CSP via identity proofing, becoming a *subscriber*. They then use their established authenticators as a *claimant* to interact with an RP, which verifies their identity with the CSP to establish an authenticated session (source: Figure 3 – NIST SP 800-63-4).

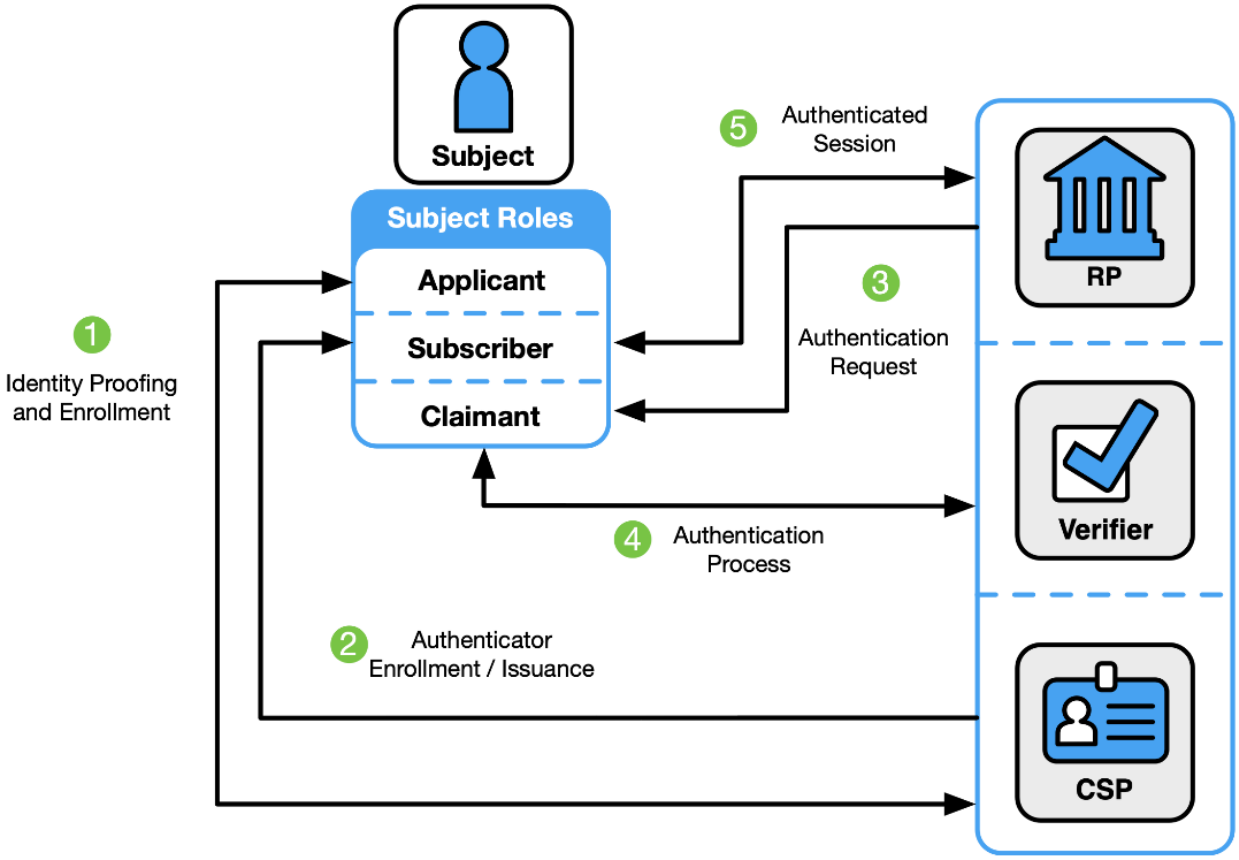


Figure 2: Digital Identity Model

AALs categorize the strength of these authentication transactions, aiming to build confidence that the *claimant* truly controls an authenticator bound to the subscriber account. For more details on authentication processes, including the choices of authenticators and their requirements at different assurance levels, please refer to NYS-S14-006 Authenticators. Higher AALs are designed to make it more difficult for malicious actors to subvert the authentication process. While AAL1 provides baseline, and AAL2 offers increased assurance, AAL3 establishes the highest level of assurance that the claimant controls the authenticators bound to the subscriber account.

4.5 Session Management

Once authenticated, it is often desirable to allow the *subscriber* to remain logged in for subsequent interactions/transactions to avoid repeated logins, particularly in federated systems (refer 4.6) requiring network coordination.

A **session** occurs between the software (i.e., the session subject) that a subscriber is using (e.g., browser, application, operating system) and the RP or CSP that the subscriber is accessing (i.e., the session host). Session types vary by application, e.g., web browser "session" cookies or mobile app session secrets.

Session management is preferred over repeated credential presentation, as the poor

usability of repeated authentication prompts subjects to find workarounds (e.g., credential caching), which defeats the authentication's intent and obscures the recency of the authenticated state.

To facilitate this behavior the following can be implemented:

- Initiate a session upon an authentication event; the session persists until terminated.
    - Session termination can occur due to *inactivity timeouts (see 4.5.2 below)* or *explicit logout events*.
- Sessions can be extended via reauthentication, which involves repeating parts of or completing the initial authentication process.

An active session's security expectations must match the strength of the initial authentication. A session cannot be assigned a higher AAL than its establishing authentication event.

- **Downgrading**: A session authenticated at a higher AAL (e.g., AAL3) *may* be treated as a lower AAL (e.g., AAL2 or AAL1). A session initiated with AAL1 must not be treated as AAL2 or AAL3.
- **Elevating**: When a higher AAL is required, step-up authentication can raise the session's AAL.

4.5.1 Session Bindings

Session binding ensures a subscriber can continue interacting with an application after initial authentication without repeated logins. A session secret must be shared between the subscriber's software and the service being accessed, thereby binding the two ends of the session. The requirements for session secrets used for *session binding* are as follows (for a more detailed reference, see Section 5 of NIST 800-63B-4):

- The session host (RP/CSP) must generate the session secret directly following a successful authentication event.
    - This generation must employ an approved random bit generator (refer to NIST-Random Bit Generation for a list of approved generators) and the secret must be a minimum of 64 bits in length.
- Secrets need to be protected by either sending them directly through a secure, verified connection, or by creating them from keys that were established using a secure, verified connection.
- Secrets must be erased or invalidated by the session subject upon subscriber logout or after overall and inactivity timeouts expire.

- Session secrets used as bearer tokens should not persist across application restarts.
- "Remember me" features, such as browser cookies, must not substitute for authentication, except in the AAL2 scenario where the inactivity limit has been exceeded but the overall time limit has not.
    - When browser cookies are utilized for session maintenance, they must be tagged for secure (HTTPS) sessions exclusively, accessible only to the minimum required hostnames/paths, and should not contain cleartext personal information.
- Session secrets should not be stored in insecure locations, such as HTML5 Local Storage, due to Cross-Site Scripting (XSS) risks.

4.5.2 Session Reauthentication & Timeouts

To ensure subscriber engagement and session security, sessions require periodic reauthentication. This session management is achieved through two key timeouts, with specific durations dependent on the AAL and detailed in Table 4 of NYS-S14-006 Authenticators.

i. **The overall timeout,** also known as the **reauthentication timeout,** sets the maximum length of a session after authentication.
ii. **Inactivity timeout** terminates sessions after a period of user inactivity.

Subscribers may be alerted by the RP before timeouts expire, allowing them to keep the session active by either performing an action or reauthenticating. Reauthentication resets both the overall and inactivity timeouts, while session activity resets the inactivity timeout only. Sessions are terminated upon timeout expiration to maintain security.

4.6 Federations and Assertions

Federation facilitates the secure exchange of authentication and subscriber attribute data across networked systems by enabling a RP to delegate subscriber authentication to an IdP. This process allows subscribers to access multiple RPs without managing individual credentials - a concept commonly known as single sign-on (SSO).

Consider various NYS public applications, such as those for driver's license renewal or tax inquiries, function as RPs. When a subscriber attempts to access one of these RPs, the application redirects the user to the centralized authentication service, "Sign in with NY.gov ID," which serves as the IdP. The subscriber then authenticates using their NY.gov ID credentials. Upon successful authentication, the NY.gov ID (IdP) issues an **assertion** to the specific NYS public application (RP) being accessed. The RP processes this assertion, verifies the subscriber's identity, and subsequently grants access to the application's functionalities without requiring re-authentication with separate credentials

for that particular RP.

Hence, the **assertion** is a digitally signed message from the IdP to the RP containing vital information about the subscriber's authentication event. It contains a **federated identifier**, which is how the RP links the assertion to the subscriber's specific account. This identifier is typically a combination of:

- A **Subject Identifier** (from the IdP) representing the subscriber's account.
- An **Issuer Identifier** (identifying the IdP).

If no federated identifier is associated with a subscriber account in federation, an account resolution process is performed.

The IdP, fulfilling a central role in federation, operates in one of two principal modes:

- The IdP directly verifies subscriber authenticators linked to an account.
- The IdP functions as software, such as a digital or cloud wallet, that receives and processes signed attribute bundles from a CSP (see 4.6.1 below).

4.6.1 Additional Roles and Functionality in Federation

In scenarios requiring the exchange of additional subscriber information beyond basic authentication, a CSP may be involved. The CSP is responsible for supplying subscriber attributes, often aggregated into *attribute bundles*, to the IdP.

- **Subscriber-Controlled Wallet**: A customer (subscriber) opens their mobile wallet app (Wallet) and registers their credit card, triggering the bank's authentication system (CSP) to verify their identity and issue a *signed attribute bundle* containing verified claims such as – card ownership, billing addresses and account standing – into the subscriber's Wallet. When the subscriber taps their phone at the grocery store checkout terminal, the Wallet acts as an IdP, presenting the signed attribute bundle as an assertion to the terminal's payment system. The terminal accepts the assertion and completes the transaction, trusting the CSPs verified claims and forwards the authenticator to the card network for further processing and payment.

For further details on *attribute bundles* and *subscriber-controlled wallet*, please refer to Section 5 'Subscriber-Controlled Wallets' of NIST SP 800-63C-4. For a comprehensive understanding of the various roles and processes within a federation, including RP, CSP, and IdP, please consult Section 3.2 'Roles' in NIST SP 800-63C-4. Additionally, Figure 1 provides an illustration of a general federation session, detailing key transaction phases (source: Figure 10 – NIST SP 800-63C-4).

4.6.2 Federation Assurance Levels

FALs categorize the robustness and security of the federation process, specifically

concerning **how authentication events and subscriber attributes are communicated from an IdP to an RP**. These levels are crucial for mitigating risks that arise from potential failures in federated identity architectures.

Table 5: Federation Assurance Levels

Assurance Level	Description
FAL1	Provides a basic level of protection for *federation transactions* and allows for a wide range of use cases and deployment decisions.
FAL2	Offers enhanced security for *federation transactions* by adding protections against attacks like assertion injection, building upon all FAL1 requirements unless superseded by more specific FAL2 rules.
FAL3	FAL3 offers the highest level of protection for *federation transactions*, ensuring high confidence in the accuracy of communicated information and mitigating compromised IdP risks through additional subscriber authentication at the RP. All FAL1 and FAL2 requirements apply unless overridden by more stringent FAL3 criteria.

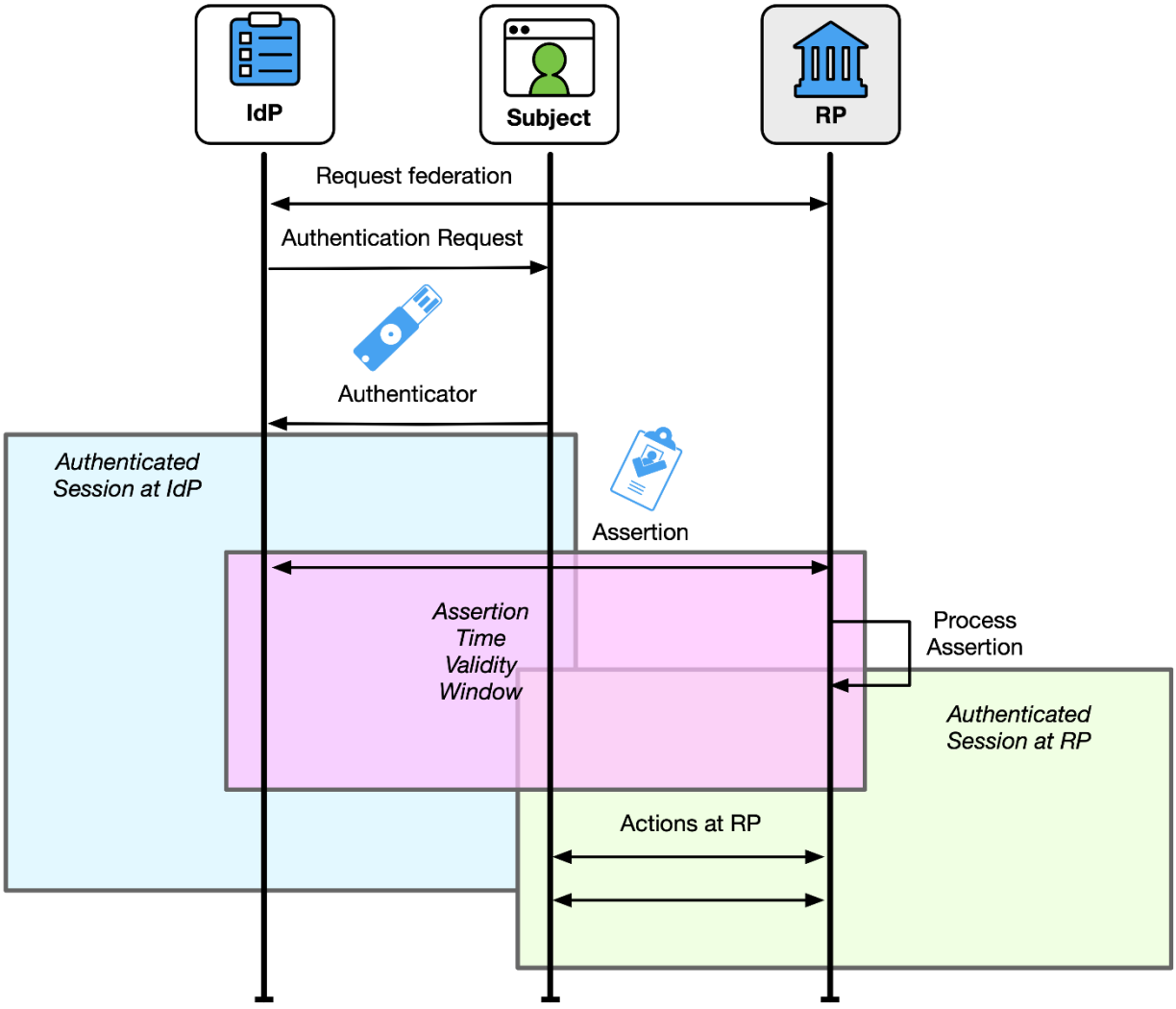


Figure 3: Federated Transaction

4.6.3 Federation Requirements: Core Concepts and Specifications

To achieve increased security for federated transactions, FALs incorporate a set of requirements. Table 6 covers the fundamental concepts of these requirements, and Table 7 then specifies how these requirements for securing federation transactions can be met at each level, along with additional supporting requirements. While combinations beyond those presented are allowed, SEs have the flexibility to implement more robust protections in one or more requirement areas at any given FAL.

Table 6: Federation Requirements

Requirement	Description

Audience Restriction	Limits *assertions* to intended RPs, ensuring a RP accepts only assertions meant for it. Prevents unknown RPs from participating in the federation or processing unknown assertions.
Replay Protection	The *assertion* is protected from being presented more than once. Prevents an attacker from replaying previously captured assertions to masquerade as a legitimate claimant to a verifier, or vice versa.
Assertion Injection Protection	The RP must be protected from attacks involving the replay, forgery, or modification of *assertions* used to bind the attacker's session to the federated identifier in the assertion and establish authenticated sessions.
Trust Agreement Establishment	*Trust agreements* are a construct that represent the set of trust relationships established to support parties (IdP, RP and CSP) in a federation transaction. They are foundational in creating an authenticated session for the subscriber at the RP. They define how IdPs and CSPs trust each other regarding subscriber access and attribute release, and how IdPs and RPs trust each other to manage subscriber identity attributes. All federation transactions must follow trust agreements between parties, which can be established independently for different relationships. These agreements can be **pre-established** by the parties before federation transaction or **subscriber-driven**, initiated by the subscriber during a federation transaction.
Identifier and Key Establishment	To communicate via federation protocols, CSPs, IdPs, and RPs must securely identify each other and associate identifiers with cryptographic keys, enabling them to verify the origin of *assertions* and attribute bundles. In the discovery phase, the RP establishes identifiers and keys for the IdP/CSP, while conversely, in the registration phase, the IdP establishes identifiers and keys for the RP. The semantics of these phases are defined by the *trust agreement* between the parties. In **manual registration**, system administrators directly exchange configuration details to establish trust before any transactions, whereas **dynamic registration** allows RPs to automatically present their configuration to an IdP over a secure channel to obtain necessary identifiers on demand.

Presentation	This describes how an *assertion* is exchanged from the IdP to the RP. Presentation occurs via two channels: the **back** channel, a direct RP-IdP connection that excludes the subject, and the **front** channel, which involves subject redirects. Assertions can be presented independently (as [5]) or alongside an authenticator from the subscriber (such as a **public key or RP-bound authenticator**). In all cases, assertion validation is performed.

Table 7: FAL Specific Requirements

Requirement	FAL1	FAL2	FAL3
Initiator of Federated Transaction	RP Recommended	RP	RP
Audience Restriction (RPs Per Assertion)	Multiple RPs allowed; single RP recommended	Single RP	Single RP
Replay Protection	Required per RP	Required	Inherited from FAL2
Assertion Injection Protection	Recommended. RP must reasonably prevent injected assertions.	Required	Required
Trust Agreement Establishment	Subscriber-driven or pre-established	Pre-established	Pre-established
Identifier and Key Establishment	Dynamic or Manual	Dynamic or Manual	Manual
Presentation	Bearer Assertion	Bearer Assertion	Holder-of-key assertion or bound authenticator

[5] An assertion that can be presented on its own as proof of the identity of the presenter.

Requirement	FAL1	FAL2	FAL3
FIPS 140 Validation	IdPs are recommended to protect their signing keys with FIPS 140 Level 1 or higher validated mechanisms.	IdPs must protect their signing keys with FIPS 140 Level 1 or higher validated mechanisms.	Inherited from FAL2
Federated Identifiers	Recommended that they do not contain unencrypted PII such as employee numbers, usernames or email addresses.	**Must not** contain unencrypted PII	Inherited from FAL2

For further details on general and FAL-specific protection mechanisms against the attacks mentioned in Table 6 and what is covered in Table 7, please refer to NIST SP 800-63C-4 Federations & Assertions.

5.0 Compliance

This standard shall take effect upon publication. Compliance is required with all enterprise policies and standards. ITS may amend its policies and standards at any time; compliance with amended policies and standards is required.

If compliance with this standard is not feasible or technically possible, or if deviation from this policy is necessary to support a business function, an SE shall request an exception through the Chief Information Security Office exception process.

6.0 Definitions of Key Terms

Term	Definition
Applicant	A *subject* undergoing the processes of identity proofing and enrollment.
Bearer assertion	An assertion that can be presented on its own as proof of the identity of the presenter.
Claimant	A *subject* whose identity is to be verified using one or more authentication protocols.
Credential	A trusted entity whose functions include identity proofing *applicants*,

Service Provider (CSP)	enrolling them into their identity service, establishing *subscriber accounts*, and registering/binding authenticators to those accounts. A CSP may be an independent third party.
Identity Provider (IdP)	The party in a federation transaction that creates an assertion for the *subscriber* and transmits the assertion to the *RP*. This is commonly the Credential Service Provider (CSP) as defined in the ITS Glossary.
Presentation attack	Presentation to the biometric data capture subsystem with the goal of interfering with the operation of the biometric system.
Presentation attack detection (PAD)	Automated determination of a *presentation attack*. A subset of presentation attack determination methods (i.e., liveness detection) involves the measurement and analysis of anatomical characteristics or voluntary or involuntary reactions to determine whether a biometric sample is being captured from a living subject that is present at the point of capture.
Relying Party (RP)	An entity that provides online transactions and services and relies upon a verifier's assertion of a *subscriber's* identity to grant access to those services. When using federation, the RP accesses the information in the *subscriber account* through assertions from an identity provider (IdP).
Subject	A natural person.
Subscriber	A *subject* who has successfully completed the identity proofing and enrollment process or who has been successfully authenticated to an online service.
Subscriber account	An account established by the *CSP* for each *subscriber* enrolled in its identity service that contains information about the subscriber and a record of any authenticators registered to the subscriber.

Except for terms defined in this standard, all terms shall have the meanings found in http://www.its.ny.gov/glossary.

7.0 Contact Information

For assistance in interpretation, all inquiries, and requests for future enhancements can be submitted to the standard owner at:

Chief Information Security Office
Reference: NYS-S26-001
NYS Office of Information Technology Services
31 British American Blvd.
Latham, NY 12110
Telephone: (518) 242-5200
Email: CISO@its.ny.gov

Statewide technology policies, standards, and guidelines may be found at the following

website: https://its.ny.gov/policies

8.0 Revision History

This policy should be reviewed consistent with the requirements set forth in ITS-P24-003 Process for Establishing Information Technology Polices, Standards and Guidelines.

Date	Description of Change	Reviewer
10/18/2013	Original Standard Release	Thomas Smith, Chief Information Security Officer
07/16/2020	Content updated to reflect NIST SP 800-63 revisions. Renamed standard from Identity Assurance (NYS-S13-004) to Digital Identity (NYS-S20-001).	Karen Sorady, Acting Chief Information Security Officer
05/20/2021	Updated Scope language	Karen Sorady, Acting Chief Information Security Officer
02/05/2025	Updated Scope language, Minor changes to reflect changes to Digital Identity Policy, Removal of Security Controls Standard, Update to current NIST 800-63 Guidelines	Chris DeSain, Chief Information Security Officer
09/08/2026	Consolidation of NYS-P20-001 Digital Identity Policy and NYS-S20-001 Digital Identity Standard. Updates throughout to reflect current NIST SP 800-63 Guidelines.	Chris DeSain, Chief Information Security Officer

9.0 Related Documents

NYS-S14-006 Authenticators

NYS-S14-013 Account Management/Access Control

NYS-S14-007 Encryption Standard

NIST SP 800-63 Digital Identity Guidelines

NIST SP 800-53 r5 Security and Privacy Controls for Information Systems and Organizations

Digital Identity Risk Management (DIRM) Alignment Form

Appendix A: Significance of Digital Identity Risk Management for State Entities

Identity, Authentication, and Federation Assurance Levels (xALS) provide an important baseline for protecting online services, but they only offer a limited perspective on digital identity risk. NIST SP 800-63-4 identifies two critical risk areas:

- **Identity System Failures**: Risks related to an online service's identity system, including failures in identity proofing, authentication, and federation.
- **Risks Introduced by the Identity System**: Threats posed by the identity system itself, such as impacts on mission delivery, privacy breaches, customer experience, and resistance to threats.

An SE that has defined its xALS may have addressed controls for unauthorized access. However, it may not have fully addressed:

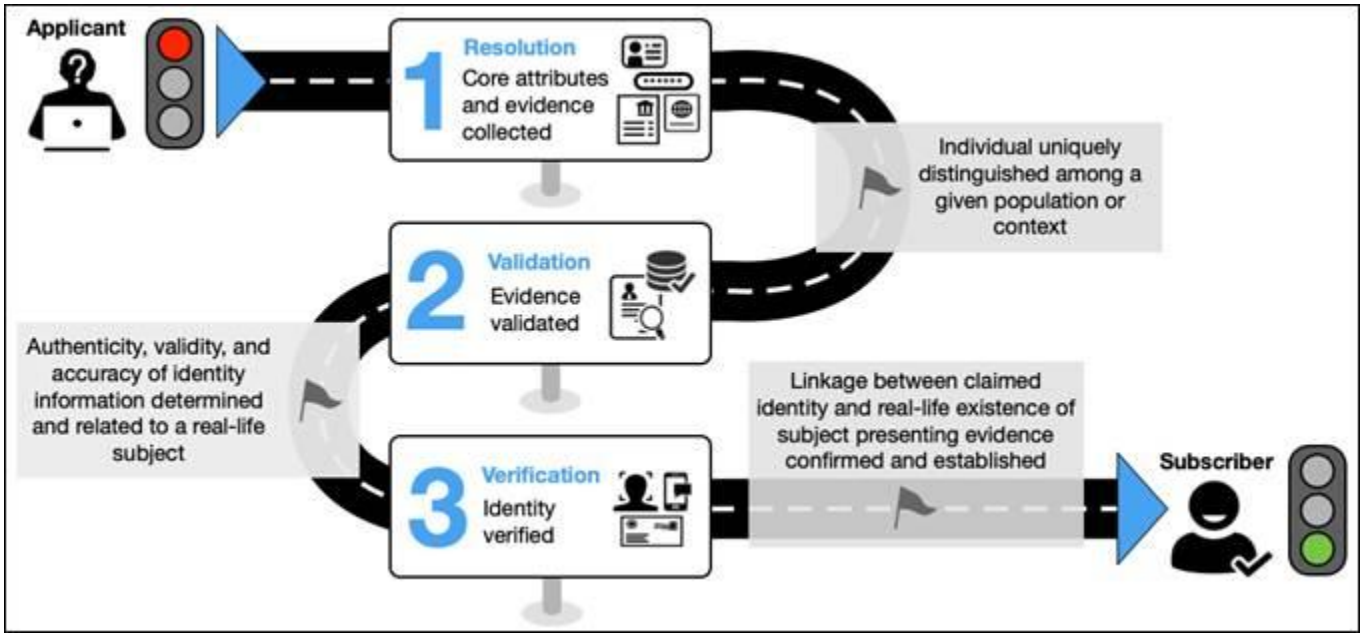
- Whether the controls are appropriately chosen.
- Whether the controls create unintended barriers for legitimate users.
- Whether the controls account for the evolving threat environment.
- Whether the controls generate privacy risks through PII collection and retention.

The Digital Identity Risk Management (DIRM) process offers the methodology to address these consequences. It requires organizations to evaluate the impact and effectiveness of their xAL choices and tailor them accordingly.

NIST 800-63-4 also emphasizes that DIRM, like risk assessment cycles, is an ongoing process. SEs are recommended to implement a continuous evaluation and improvement program that monitors fraud metrics, authentication failures, user abandonment rates, and the shifting threat landscape.

For an SE managing multiple online services for diverse citizen populations, the absence of a formalized DIRM process means that the xALs decisions made at a point in time are not revisited, fraud trends in digital identity go undetected, and the agency lacks the documented, auditable basis for responsible digital identity governance - an expectation that is increasingly reflected in federal grant conditions, audit standards and interoperability requirements.

Appendix B : An example of the three-step identity proofing process.



Appendix C: Strengths of Identity Evidence

Strength	Attributes of Identity Evidence
Fair	• **Authenticity:** The evidence must be issued by a source that has formally verified the claimed identity through established procedures, ensuring the identity is genuinely linked to the individual. Examples include identity verification by financial institutions or mobile network operators. • **Direct Receipt:** The issuance process must ensure the evidence is delivered directly to the individual, whether through postal mail, in-person issuance, or a secure remote provisioning method. • **Completeness of Identification:** The evidence needs to have the name of the claimed identity. It also needs at least one of these: a reference number, a facial image or biometric data (like fingerprint), or enough other details to uniquely identify them. • **Security and Tamper Resistance:** The evidence should have built-in protections, like special printing, holograms, or secure digital signatures, that make it hard to copy or forge. • For validation and verification of **fair** evidence, see Table 3 and Table 4.
Strong	• **Authenticity**: The evidence is issued by a source that has confirmed the claimed identity through *written* procedures (e.g., identity proofing at IAL2 or above) to confirm the applicant's identity, and these procedures are subject to recurring oversight by regulatory or publicly accountable institutions. Examples include evidence issued by financial institutions that have customer identity verification obligations under the Customer Identification Program (CIP) rule. • **Direct Receipt**: Same as Fair evidence • **Completeness of Identification**: The evidence includes the name of the claimed identity, a unique reference number or attributes, and a facial image or other biometric characteristic. • **Security and Tamper Resistance**: Same as Fair evidence • For validation and verification of **strong** evidence, see Table 3 and Table 4.
Superior	• **Authenticity:** The evidence is issued by a source that has confirmed the claimed identity through written procedures with high confidence, subject to recurring oversight by regulatory or publicly accountable institutions, and the subject participated in an attended enrollment and identity proofing

Strength	Attributes of Identity Evidence
	process that confirmed their physical existence. ● **Direct Receipt:** Same as Strong evidence ● **Completeness of Identification:** The evidence includes the name of the claimed identity, at least one reference number that uniquely identifies the person, and a facial image or other biometric characteristic of the person. ● **Security and Tamper Resistance:** In addition to Strong evidence requirements, the evidence identity attributes must be cryptographically protected and validated by the issuing source's digital signature. ● For validation and verification of **superior** evidence, see Table 3 and Table 4.

Appendix D: Identity Proofing Types

Proofing Type	Description
Remote Unattended	Resolution, validation, and verification processes are **fully automated, requiring no interaction with a proofing agent or trusted referee**. CSP does not control the location or devices used.
Remote Attended	Resolution, validation, and verification processes are **conducted through a secure video session with a proofing agent or trusted referee**. CSP does not control the location or devices used.
On-Site Unattended	Resolution, validation, and verification processes **are fully automated and occur at a physical location on devices controlled by the CSP, but do not require interaction with a proofing agent or trusted referee**. The individual interacts with a controlled workstation or kiosk.
On-Site Attended	Resolution, validation, and verification processes are **completed by the applicant in a physical setting in the presence of a proofing agent or trusted referee**. This agent or referee can be co-located with the subject or interact via a kiosk or device. The physical location and devices are controlled by the CSP.

Appendix E: Fraud Mitigation Strategies

Threat Category	Threat/Attack	Mitigation Strategies
Impersonation	Attackers fraudulently use another individual's identity or identity evidence	• Identity Validation: Biometrically compare the applicant to validated identity evidence or data. • Identity Verification: Use out-of-band engagement (like confirmation codes) and provide proofing notices. • Identity Verification: Employ Presentation Attack Detection (PAD) to ensure the applicant is genuinely present. • Check against vital statistics repositories (e.g., Death Master File). • Analyze fraud, transactions, and behavior for indicators of malicious account establishment.
	Attackers create fake video feed to impersonate a real-life person	• Identity Verification: Employ a combination of active and passive Presentation Attack Detection (PAD). • Utilize authenticated protected channels for device-to-server communications. • Authenticate biometric sensors. • Monitor and analyze incoming video and image files for forgery or modification. • Implement active countermeasures.
False or fraudulent representation	Attackers create or modify evidence to claim an identity	• Attribute Validation: Confirm core attributes with authoritative or credible sources. • Evidence Validation: Verify the physical or digital security features of the presented evidence.
	Attackers fabricate evidence of an identity that is not associated with a real person	• Evidence Collection: Gather identity evidence from the applicant. • Attribute Validation: Validate core attributes using authoritative or credible sources. • Evidence Verification: Compare applicant biometrics against validated identity evidence or biometric data. • Perform checks against vital statistics repositories (e.g., Death Master File).
	Attackers associate false attributes or information with a legitimate identity	• Geographic restrictions on traffic. • Identity Validation: Validation of core attributes with authoritative or credible sources.

Threat Category	Threat/Attack	Mitigation Strategies
	Attacker leverages scripts and automated processes to rapidly generate large volumes of enrollments	• Evidence Verification: Use out-of-band engagement methods, such as confirmation codes. • Deploy Web Application Firewall (WAF) controls and bot detection technology. • Implement biometric verification and liveness detection mechanisms. • Analyze traffic and network activity to identify indications of malicious traffic.
Social engineering attacks	Attacker convinces a legitimate applicant to provide identity evidence or complete the identity proofing process under false pretenses	• Train trusted referees to identify signs of coercion or distress. • Use out-of-band engagement and provide proofing notices to a validated address. • Educate end users on common threats and schemes. • Offer on-site, in-person attended identity proofing options.